

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (scanner CVSS-weighted, source_sha `61ed8c3`) · Generated 2026-07-13 · Model: `0.5·CVE + 0.3·exposure + 0.2·criticality`

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix
1	com.fastxml...:jackson-databind (typosquat)	2.9.8	CRITICAL	9.0	Dependency-confusion / typosquat — REMOVE	remove
2	log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0, Log4Shell)	2.17.1
3	jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 et al. (9.8, 53 CVEs)	2.9.10.8
4	log4j-api	2.14.1	HIGH	6.8	CVE-2026-34479 (7.5)	2.17.1
5	mysql-connector-java	8.0.30	HIGH	6.7	CVE-2023-22102 (8.3) + GPL-2.0 license VIOLATION	8.0.33
6	protobuf-java (transitive)	3.19.4	HIGH	6.7	CVE-2024-7254 et al. (7.5, 4 CVEs)	3.25.5
7	guava	24.1.1-jre	HIGH	6.3	CVE-2023-2976 (7.1)	32.0.0-jre
8	jackson-annotations (transitive)	2.9.0	MEDIUM	5.5	CVE-2018-1000873 (6.5)	2.9.10
9	commons-io	2.4	MEDIUM	5.2	CVE-2021-29425 (4.8)	2.14.0
10	commons-lang3	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3)	3.18.0

Remaining 13 dependencies (*jackson-core* and *guava/junit* transitives) scored **Low** — no known CVEs, default business criticality; see `depscan-risk-report.json` for the full ranked list of all 24 entries.

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
jackson-databind (typosquat)	0.0	10.0	5.0 (override)	9.0
log4j-core	10.0	8.0	2.0 (default)	7.8
jackson-databind	10.0	8.0	2.0 (default)	7.8
log4j-api	8.0	8.0	2.0 (found: used in DiscountCalculator)	6.8
mysql-connector-java	8.3	7.0	2.0 (default)	6.7
protobuf-java	9.0	6.0	2.0 (default)	6.7
guava	7.6	7.0	2.0 (default)	6.3

Summary

Band	Count
CRITICAL	1

HIGH	6
MEDIUM	3
LOW	14

Priority recommendations

1. **P0** — Remove the typosquatted `com.fastxml.jackson.core:jackson-databind` dependency entirely (dependency-confusion attack vector; does not resolve on Central and was only reachable via a blocked, untrusted plain-HTTP mirror).
2. **P0** — Upgrade `log4j-core / log4j-api` `2.14.1` → `2.17.1` (Log4Shell CVE-2021-44228, CVSS 10.0, actively exploited in the wild; actually used in `DiscountCalculator`).
3. **P1** — Upgrade `jackson-databind` `2.9.8` → at least `2.9.10.8` (ideally the current `2.x/3.x` line) — 53 known CVEs, 16 rated CRITICAL (9.8) deserialization RCEs.
4. **P1** — Upgrade `mysql-connector-java` `8.0.30` → `8.0.33` (CVE-2023-22102) **and** resolve the GPL-2.0-with-FOSS-exception license policy violation (legal review or swap to a permissively-licensed driver).
5. **P1** — Upgrade transitive `protobuf-java` `3.19.4` → `3.25.5` (pulled in via `mysql-connector-java` ; 4 HIGH CVEs).
6. **P2** — Upgrade `guava` `24.1.1-jre` → `32.0.0-jre+` (CVE-2023-2976 insecure temp-dir, CVE-2020-8908); expect a major-version review.
7. **P3** — Routine bumps: `commons-io` → `2.14.0+`, `commons-lang3` → `3.18.0+`, `jackson-annotations` → `2.9.10+`.

Stage 3/4 note — applied fix versions differ from initial suggestions

The `Fix` column above reflects the Stage 2 scanner's first-pass suggestion. Stage 3 remediation and the Stage 4 Grype gate re-scan (PR #77) found three of these insufficient to clear every CVE; the actually applied, verified-clean versions are: `jackson-databind` → **2.18.8** (not `2.9.10.8` — Stage 4 Grype found `2.16.0` still had 2 High GHSA findings), `log4j-core / log4j-api` → **2.25.4** (not `2.17.1`), `mysql-connector-java` → **com.mysql:mysql-connector-j:8.2.0** (not `mysql:mysql-connector-java:8.0.33` , which is still vulnerable — Oracle relocated the coordinate). See `CVE-Report.md` for the full verified-fixed detail. The GPL-2.0 license violation on the `mysql` connector is unchanged by the version bump and remains a separate follow-up (issue #76) — it is the sole reason the Stage 4 gate still returns BLOCK on this PR.

Machine-readable source: `depscan-risk-report.json` (24 ranked entries). Full finding detail: `depscan-report.json` . Generated by the Dependency & Supply-Chain Plugin — Stage 2 (Risk Scoring Agent).